

REPORTE DE VALIDACIÓN

MediPlanner - Errores de Consulta

Fecha: 24 de marzo de 2026 a las 12:46 p.m.

RESUMEN EJECUTIVO

Durante las pruebas automatizadas de estrés realizadas en el módulo de consulta de MediPlanner, se identificaron un total de 68 vulnerabilidades en las secciones de la aplicación. El hallazgo principal es que la aplicación NO implementa validación de inputs en ninguno de los campos de texto ni en la mayoría de los campos numéricos, lo que permite la inyección de código malicioso y datos inconsistentes.

RESUMEN POR SECCIÓN

- SIGNOS VITALES: Se encontraron 16 vulnerabilidades y 0 validaciones correctas.
- GENERAL: Se encontraron 12 vulnerabilidades y 0 validaciones correctas.
- EXPLORACIÓN: Se encontraron 6 vulnerabilidades y 0 validaciones correctas.
- DIAGNÓSTICO: Se encontraron 12 vulnerabilidades y 0 validaciones correctas.
- TRATAMIENTO (RSW): Se encontraron 6 vulnerabilidades y 0 validaciones correctas.
- MEDICAMENTOS: Se encontraron 15 vulnerabilidades y 6 validaciones correctas.
- NOTAS DEL MÉDICO: Se encontraron 3 vulnerabilidades y 0 validaciones correctas.
- SERVICIOS: Se encontraron 6 vulnerabilidades y 0 validaciones correctas.

TOTAL GENERAL: 6 validaciones correctas | 76 vulnerabilidades encontradas.

1. SIGNOS VITALES

En la sección de signos vitales se probaron los siguientes campos: peso, talla, presión arterial, temperatura, frecuencia cardíaca, oxigenación y frecuencia respiratoria.

Resultado: Se encontraron 16 vulnerabilidades. Ninguno de los campos valida el tipo de dato que recibe. Por ejemplo, en el campo de peso se pudieron ingresar letras como "abc123" y el sistema únicamente conservó los números, aceptando también valores extremos como 99999 kg.

Los campos de presión arterial permitieron el ingreso de letras y valores peligrosos como 999/999 mmHg. La temperatura aceptó tanto texto como valores fuera de rango como 150°C.

2. GENERAL

En la sección general se probaron los campos de texto y textareas disponibles.

Resultado: Se encontraron 12 vulnerabilidades. Todos los tipos de pruebas fueron aceptados sin validación alguna.

3. EXPLORACIÓN

En la sección de exploración física se probaron las textareas de observaciones.

Resultado: Se encontraron 6 vulnerabilidades. Todos los ataques de texto fueron aceptados.

4. DIAGNÓSTICO

En la sección de diagnóstico se probaron los campos de impresión diagnóstica y notas.

Resultado: Se encontraron 12 vulnerabilidades. No existe sanitización de los inputs de texto.

5. TRATAMIENTO (RSW Editors)

En la sección de tratamiento se probaron los editores de texto enriquecido (RSW Editors) donde se ingresan las indicaciones generales.

Resultado: Se encontraron 6 vulnerabilidades. Los editores rich text aceptaron código JavaScript, inyecciones SQL y textos muy largos sin restricciones.

6. MEDICAMENTOS

En el formulario de medicamentos se probaron los campos numéricos: cantidad, frecuencia y duración del medicamento.

Fortalezas encontradas (6):

- El sistema bloquea el ingreso de letras como "tres" o "abc" en los campos numéricos.
- El sistema bloquea símbolos especiales como "!@#\$\$%" en estos campos.

Vulnerabilidades encontradas (15):

- El sistema permite valores negativos como -10 o -50.
- El sistema permite el valor cero (0) cuando debería ser mayor a cero.
- El sistema permite valores extremos irrealistas como 999999.
- El sistema permite números con múltiples puntos decimales como 12.5.8.
- El sistema permite mezcla de números y letras como "abc123" conservando solo los números.

7. NOTAS DEL MÉDICO

En la sección de notas del médico se probaron los editores de texto enriquecido.

Resultado: Se encontraron 3 vulnerabilidades. Los mismos problemas que en tratamiento: XSS, SQL injection y textos largos aceptados.

8. SERVICIOS

En la sección de servicios se probaron los campos de descripción.

Resultado: Se encontraron 6 vulnerabilidades. Sin validación de inputs de texto.

TIPOS DE ATAQUE QUE FUERON ACEPTADOS

Los siguientes tipos de inputs maliciosos fueron aceptados en múltiples secciones:

- XSS Script: Código JavaScript como `<script>alert("xss")</script>`
- SQL Injection: Comandos SQL como `' OR '1'='1`
- Template Injection: Expresiones como `{{alert(1)}}`
- Caracteres Especiales: Símbolos como `!@#$$%^&*()`
- Solo Espacios: Strings que contienen solo espacios en blanco
- Texto Largo: Más de 500 caracteres sin validación de longitud máxima

RECOMENDACIONES DE SEGURIDAD

Basándose en los hallazgos de esta auditoría, se recomiendan las siguientes acciones correctivas:

1. Implementar validación de tipo de datos en todos los campos numéricos. Los campos como peso, talla, temperatura, frecuencia cardíaca, etc. deben validar que el input sea exclusivamente numérico.
2. Agregar validación de rango razonable para cada campo. Por ejemplo: peso entre 0-500 kg, temperatura entre 30-45°C, presión arterial sistólica entre 60-250 mmHg.
3. Sanitizar todos los inputs de texto para prevenir ataques XSS. El contenido ingestado debe ser

codificado o escapado antes de ser almacenado o mostrado.

4. Implementar validación de longitud máxima de texto en todos los campos de texto libre. Establecer límites razonables (ej: 1000 caracteres máximo).

5. Bloquear caracteres especiales en campos que no los requieran. Utilizar listas blanca (whitelist) de caracteres permitidos.

6. Validar datos tanto en el cliente como en el servidor. La validación del lado del cliente puede ser fácilmente burlada.

7. Implementar protección contra SQL Injection utilizando consultas parametrizadas u ORM.

8. Agregar mensajes de error claros y amigables que guíen al usuario sobre el formato esperado.

9. Realizar una auditoría de seguridad completa por parte de un equipo especializado.

CONCLUSIONES

La aplicación MediPlanner en su módulo de consulta presenta múltiples vulnerabilidades relacionadas con la falta de validación de inputs. Esto representa un riesgo significativo para la integridad de los datos y la seguridad de la aplicación.

Es prioritaria la implementación de validaciones robustas en todos los campos, especialmente en aquellos que almacenan información médica crítica como los signos vitales.